

Sécurité et gouvernance

Statut : source de vérité Dernière mise à jour : 2026-08-01

Rôle du document

Ce document fixe les principes de sécurité et de gouvernance des données de L'Édifice, la classification qui en découle, et les mécanismes techniques qui les font tenir. Il ne redéfinit pas les gestes de suppression et d'export — voir 11-modularite-configuration.md — ni le modèle de données qu'il protège — voir 12-modele-de-donnees.md.

Contexte : priorité actuelle

La sécurité n'est pas un chantier parmi d'autres en ce moment : c'est le chantier qui précède tous les autres. Un audit complet est en cours, et aucune nouvelle fonctionnalité ne démarre tant qu'il n'est pas clos — voir 02-strategie-produit.md. Construire de nouvelles surfaces sur une base dont les failles connues ne sont pas corrigées reviendrait à agrandir une maison dont les fondations n'ont pas été vérifiées.

Principes de sécurité

Souveraineté avant commodité. Quand un choix d'ergonomie entre en conflit avec un choix de protection de la donnée, la protection gagne. Si une fonctionnalité simplifie l'usage en élargissant l'accès à une donnée au-delà du strict nécessaire, elle est retravaillée jusqu'à ce qu'elle n'ait plus à le faire — jamais livrée en l'état au nom du confort.

Chiffrement au repos et en transit. Toute donnée stockée est chiffrée au repos. Toute donnée qui circule — entre client et serveur, entre serveur et service tiers — est chiffrée en transit. Aucune exception silencieuse, même pour une donnée jugée mineure.

Moindre privilège. Chaque connexion externe demande le plus petit ensemble de scopes OAuth qui permette la fonctionnalité, jamais un scope large « au cas où ». La lecture seule est préférée à l'écriture partout où la fonctionnalité le permet : si L'Édifice n'a pas besoin d'écrire dans un service tiers, il ne demande pas la permission de le faire.

Traçabilité complète. Toute action sensible — connexion, modification de configuration, suppression, action déclenchée par l'IA — laisse une trace dans un journal d'audit, horodatée et attribuée à son origine. Une action sensible sans trace n'est pas considérée comme terminée, quel que soit son résultat.

Séparation secrets et code. Aucun secret — clé API, jeton, mot de passe — ne vit dans le code versionné. Les secrets vivent exclusivement dans des variables d'environnement, gérées hors du dépôt, jamais committées même temporairement.

Classification des données

Critique. Données dont la fuite aurait une conséquence grave et durable — jetons d'accès, identifiants de connexion, données de santé précises, données financières. Protection maximale : chiffrement renforcé, accès le plus restreint possible, aucune exposition même partielle côté client.

Sensible. Données personnelles qui, sans être critiques, révèlent des informations privées — habitudes, localisation approximative, contenu d'un journal. Accès limité au propriétaire, jamais exposées à un tiers sans consentement explicite.

Standard. Données métier ordinaires sans caractère personnel marqué — statut d'une tâche, titre d'un projet. Protection standard : accès restreint au propriétaire par défaut.

Public. Données destinées par nature à être vues par d'autres — un contenu publié sur une marque, une page publique. La protection porte sur l'intégrité, pas sur la confidentialité : personne d'autre que le propriétaire ne peut la modifier, mais sa visibilité n'a pas à être restreinte puisqu'elle est publique par destination.

Mécanismes techniques

RLS Supabase. Chaque table métier porte une politique de sécurité au niveau ligne qui restreint l'accès au propriétaire réel de la donnée — l'identifiant utilisateur du modèle de données, voir `12-modele-de-donnees.md` — jamais une politique ouverte par défaut. Une politique qui accorderait un accès plus large qu'au propriétaire est une anomalie à corriger, pas une optimisation à conserver.

OAuth2 avec redirect URI dynamique. Le redirect URI se résout dynamiquement selon l'environnement — local, prévisualisation, production — plutôt que d'être codé en dur, ce qui évite qu'un environnement de test ne devienne une faille exploitable en cross-domain. L'état du flow OAuth est signé et lié explicitement à l'utilisateur qui l'a démarré, pour qu'aucun visiteur non authentifié ne puisse faire écrire un jeton dans le magasin partagé.

Tokens chiffrés et rotation. Tout jeton d'accès stocké est chiffré au repos et fait l'objet d'une politique de rotation. Aucun jeton ne vit indéfiniment sans renouvellement ni contrôle.

Droit à l'oubli et portabilité

Le droit à l'oubli et la portabilité des données ne sont pas des mécanismes à part : ce sont l'application directe de deux des cinq gestes du cycle de vie des données décrits dans `11-modularite-configuration.md` — Exporter pour la portabilité, Supprimer le compte pour le droit à l'oubli. Ce document n'en reprend pas le détail.

Ensemble, l'export, la suppression physique et sa propagation aux tiers forment le socle RGPD par défaut sur lequel repose l'ouverture publique de L'Édifice. Ce n'est pas une couche de conformité ajoutée après coup pour satisfaire une obligation légale au moment de l'ouverture — c'est une conséquence directe de ce qui est déjà exigé pour l'usage personnel qui précède cette ouverture.